

Lab: File Path Traversal, Traversal Sequences Stripped Non-Recursively

PortSwigger Web Security Academy — Parcial I: Fundamentos de Ciberseguridad

1. Nombre del laboratorio

File path traversal, traversal sequences stripped non-recursively

Fuente oficial:

<https://portswigger.net/web-security/file-path-traversal/lab-sequences-stripped-non-recursively>

2. Nivel

Practitioner.

3. Tipo de explotación

Path Traversal / Directory Traversal (CWE-22), con bypass de un filtro de saneamiento no recursivo (elimina secuencias "../" en un solo paso) mediante secuencias de traversal anidadas/superpuestas.

4. Objetivo del laboratorio

La aplicación vulnerable sirve imágenes de producto a través de GET /image?filename=NOMBRE. A diferencia de los laboratorios anteriores, aquí el servidor elimina activamente las secuencias "../" del valor de filename antes de usarlo. El objetivo es identificar que esa eliminación se aplica una sola vez (no recursivamente) y construir un payload que, tras el filtrado, se reconstruya en una secuencia de traversal válida para leer /etc/passwd.

5. Explicación técnica de la vulnerabilidad

5.1 Concepto y mecanismo del filtro no recursivo

El servidor sanea el parámetro filename eliminando la subcadena "../" en cuanto la encuentra, pero realiza esta eliminación en un único paso (una sola pasada) sobre la cadena original, en lugar de repetir el proceso hasta que ya no queden coincidencias. Esta distinción —una pasada vs. un bucle hasta punto fijo— es exactamente lo que hace explotable al filtro.

Al enviar la secuencia//....//etc/passwd, el filtro localiza la subcadena "../" escondida dentro de cada grupo de cuatro puntos y dos barras (....//), y la elimina. Pero al retirar esos tres caracteres del centro, los caracteres que quedan a los lados (dos puntos antes y una barra después) se reagrupan automáticamente en una nueva secuencia "../" completa, que el filtro ya no vuelve a revisar porque su pasada de limpieza ya terminó.

5.2 Por qué falla el bypass de ruta absoluta del laboratorio anterior

En el laboratorio de "absolute path bypass", el servidor construía la ruta final con una función de unión de rutas que, al recibir una ruta absoluta, descartaba el directorio base. Aquí, en cambio, el intento con filename=/etc/passwd responde 400 Bad Request ("No such file"): esto indica que este servidor concatena el directorio base con filename de forma literal (por ejemplo, /var/www/images/ + /etc/passwd), en lugar de usar una función de unión de rutas con ese comportamiento

especial. El resultado, algo como `/var/www/images/etc/passwd`, simplemente no existe, así que la ruta absoluta no ofrece ninguna ventaja en este servidor: la única vía de explotación es evadir el filtro de secuencias relativas.

5.3 Reconstrucción carácter por carácter del payload

Tomando un solo grupo `"..../"` (cuatro puntos seguidos de dos barras) y aplicando una eliminación única de la subcadena `"../"`:

- Cadena original: `....//` (posiciones 1 a 6)
- El filtro encuentra `"../"` exactamente en las posiciones 3-4-5 (el tercer punto, el cuarto punto y la primera barra) y la elimina.
- Lo que queda son los caracteres de las posiciones 1, 2 y 6: dos puntos y una barra, es decir, otra vez `"../"` — pero ahora el filtro ya pasó por esa zona y no vuelve a analizar el resultado.

Repitiendo esta lógica en los tres grupos del payload `....//....//....//etc/passwd`, el resultado final después del filtrado es exactamente `../../etc/passwd`, la misma secuencia clásica de traversal usada en el laboratorio "simple case", ahora reconstruida a partir de una entrada que el filtro consideró segura.

5.4 Impacto y clasificación estándar

El impacto es el mismo de la familia de laboratorios de path traversal: exposición de información sensible del sistema (confidencialidad), clasificada como CWE-22 (Improper Limitation of a Pathname to a Restricted Directory) y encuadrada en OWASP Top 10 2021 — A01:2021 Broken Access Control. La causa raíz específica de este caso —una sanitización de un solo paso que no se aplica de forma recursiva/iterativa— es un patrón de fallo bien documentado y suele catalogarse como saneamiento incompleto (incomplete blacklist / improper neutralization), ya que remueve el patrón peligroso pero no revalida la cadena resultante.

La defensa efectiva combina no confiar en ningún saneamiento basado en eliminar patrones específicos, canonicalizar la ruta resultante y validarla contra el directorio base permitido, y aplicar el principio de menor privilegio como capa adicional (ver sección 8, Mitigación recomendada).

6. Procedimiento paso a paso

Paso 1 — Reconocimiento del laboratorio

Se accede a la descripción oficial del laboratorio, confirmando el nivel Practitioner y el objetivo: la aplicación elimina las secuencias de traversal del parámetro filename antes de usarlo.

Lab: File path traversal, traversal sequences stripped non-recursively

PRACTITIONER



This lab contains a path traversal vulnerability in the display of product images.

The application strips path traversal sequences from the user-supplied filename before using it.

To solve the lab, retrieve the contents of the `/etc/passwd` file.



ACCESS THE LAB

Figura 1. Descripción oficial del laboratorio en PortSwigger Web Security Academy.

Paso 2 — Interceptación y localización del endpoint

Con Burp Suite interceptando el tráfico, se navega por la tienda y se localiza en el historial de peticiones el endpoint GET /image?filename=X.jpg utilizado para servir las imágenes de producto.

Time	Type	Direction	Method	URL
14:10:08 23 Se...	WS	→ To server		https://0a4100ce049c22a082cd2e0a00b100a5.web-security-academy.net/academyLabHeader
14:10:30 23 Se...	HTTP	→ Request	POST	https://www.youtube.com/youtubei/v1/log_event?alt=json
14:10:32 23 Se...	HTTP	→ Request	GET	https://0a4100ce049c22a082cd2e0a00b100a5.web-security-academy.net/image?filename=7.jpg
14:10:32 23 Se...	HTTP	→ Request	GET	https://0a4100ce049c22a082cd2e0a00b100a5.web-security-academy.net/image?filename=3.jpg
14:10:32 23 Se...	HTTP	→ Request	GET	https://0a4100ce049c22a082cd2e0a00b100a5.web-security-academy.net/image?filename=8.jpg
14:10:32 23 Se...	HTTP	→ Request	GET	https://0a4100ce049c22a082cd2e0a00b100a5.web-security-academy.net/academyLabHeader

Request	
Pretty	Raw
1 GET /image?filename=3.jpg HTTP/2	
2 Host: 0a4100ce049c22a082cd2e0a00b100a5.web-security-academy.net	
3 Cookie: session=8a0C1k13ehUJjy9FxUd3savvCEJyTwQK	
4 Sec-Ch-Ua-Platform: "Windows"	
5 Accept-Language: es-419,es;q=0.9	
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"	
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36	
8 Sec-Ch-Ua-Mobile: ?0	
9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8	
10 ...	

Figura 2. Historial de peticiones mostrando solicitudes al endpoint /image?filename=.

Paso 3 — Envío de la solicitud a Repeater

Se envía una de las solicitudes de imagen al módulo Repeater para manipular el parámetro filename de forma controlada.

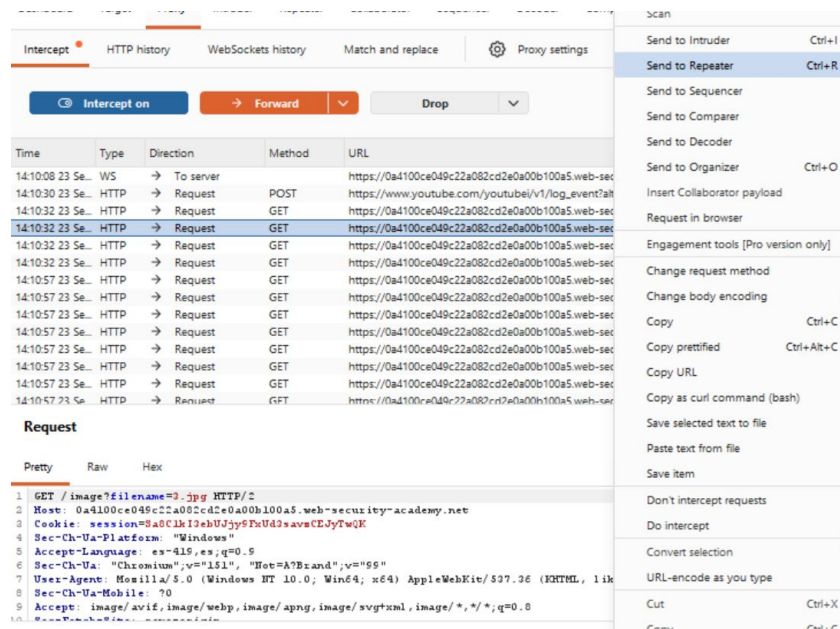


Figura 3. Envío de la solicitud interceptada al módulo Repeater ("Send to Repeater").

Paso 4 — Prueba de ruta absoluta (bloqueada)

Se prueba primero el payload /etc/passwd (la técnica que funcionó en el laboratorio anterior). El servidor responde con 400 Bad Request y "No such file", confirmando que aquí la construcción de rutas no favorece las rutas absolutas.

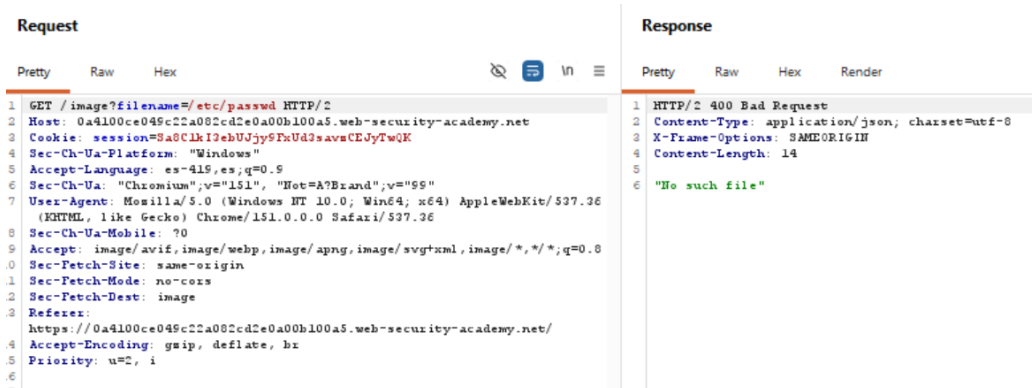


Figura 4. Payload /etc/passwd bloqueado (400 Bad Request, "No such file").

Paso 5 — Bypass del filtro no recursivo

Se sustituye filename por ../.../.../.../etc/passwd. El filtro elimina la secuencia "../" interna de cada grupo en una sola pasada, dejando tras de sí una nueva secuencia "../" que no vuelve a ser revisada. El servidor responde 200 OK con el contenido completo de /etc/passwd.

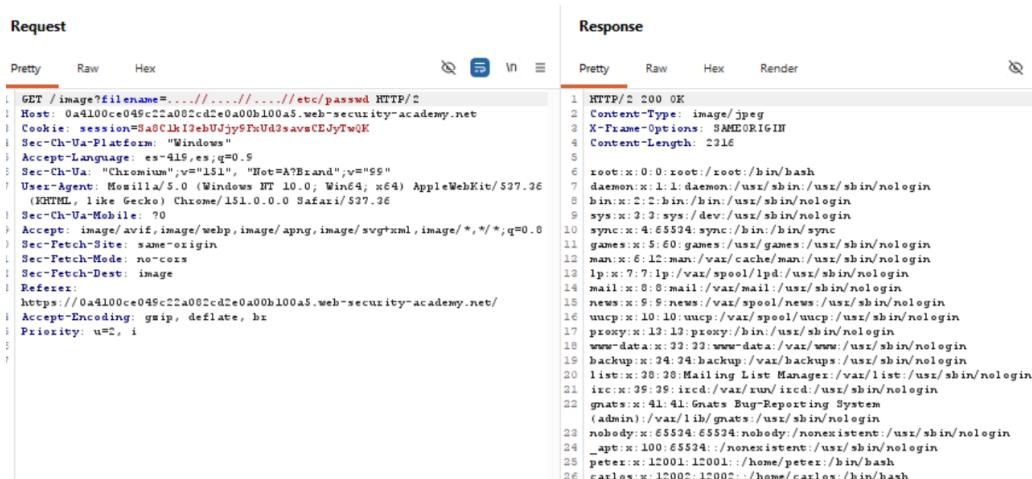


Figura 5. Payload ../.../.../.../etc/passwd — respuesta 200 OK con el contenido del archivo.

Paso 6 — Confirmación de resolución del laboratorio

PortSwigger Web Security Academy confirma la explotación exitosa marcando el laboratorio como "Solved".

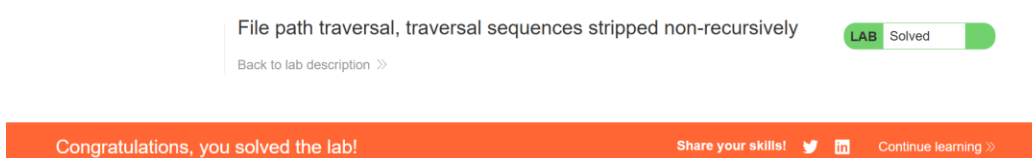


Figura 6. Confirmación "Lab Solved" en PortSwigger Web Security Academy.

7. Explicación del payload

Payload bloqueado:

/etc/passwd

Payload exitoso:

....//....//....//etc/passwd

Funcionamiento técnico:

- El primer payload no contiene secuencias "../", por lo que pasa el filtro sin cambios; pero como el servidor concatena literalmente el directorio base con filename (sin la función de unión de rutas del laboratorio anterior), la ruta absoluta no reemplaza el directorio base y el archivo resultante no existe (400 Bad Request).
- El segundo payload está compuesto por tres grupos "....//". El filtro detecta y elimina la subcadena "../" ubicada en el centro de cada grupo (los caracteres 3, 4 y 5 de cada bloque de cuatro puntos y dos barras).
- Al eliminar esos tres caracteres, los dos puntos sobrantes al inicio del grupo y la barra sobrante al final se quedan adyacentes, formando una nueva secuencia "../" completa — pero el filtro ya completó su única pasada y no vuelve a examinar el resultado.
- Tras el filtrado, la cadena resultante es exactamente ../../etc/passwd, la secuencia de traversal clásica que sube tres niveles hasta la raíz del sistema de archivos y desciende hacia etc/passwd.
- El servidor concatena esta ruta ya "limpia" (según el filtro) con su directorio base, y el sistema operativo la resuelve al abrir el archivo, entregando su contenido en la respuesta HTTP.

La lección central de este laboratorio es que remover un patrón peligroso de una cadena no es lo mismo que validar que la cadena resultante sea segura: el orden de operaciones (sanear una sola vez, sin revalidar) crea una ventana de explotación aunque la intención del filtro sea correcta.

8. Mitigación recomendada

- Aplicar el saneamiento de forma recursiva/iterativa hasta alcanzar un punto fijo (es decir, repetir la eliminación de "../" hasta que una nueva pasada no produzca cambios), o mejor aún, rechazar directamente cualquier entrada que contenga "." en cualquier forma, en lugar de intentar "limpiarla".
- Preferir un identificador indirecto (ID numérico o nombre interno) traducido a la ruta real mediante un mapeo controlado del servidor, evitando por completo construir rutas a partir de la entrada del usuario.
- Validar la entrada contra una lista blanca (allow-list) de nombres o extensiones permitidos, en lugar de intentar eliminar patrones peligrosos de una lista negra.
- Canonicalizar la ruta final (resolver "../", enlaces simbólicos, dobles barras) y verificar que el resultado permanezca dentro del directorio base permitido, después de cualquier saneamiento, nunca antes.
- Aplicar el principio de menor privilegio: ejecutar el proceso del servidor con un usuario restringido sin permisos de lectura sobre archivos sensibles del sistema operativo.
- Aislar el directorio de archivos servidos mediante chroot jails, contenedores o sistemas de archivos de solo lectura para el contenido público.
- Registrar y monitorear solicitudes con patrones anómalos en parámetros de archivo (secuencias de puntos repetidas, rutas absolutas, codificaciones) para detectar intentos de explotación.